SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct: (192472388).

I S. Deva Dharshini *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

192472350.

S. Deva Dhashini

A company hires you to test its network but gives you only one line authorization with no defined scope. Do you exploit it to prove impact? Justify your answer using ethical hacking principles

If I discover a critical vulnerability in a system that is not included in the authorization email, I will not exploit it without obtaining additional written permission.

Ethical approach:

- Authorization: Test only systems that are explicitly authorized

Scope limitation: Do not access (or) modify systems outside the agreed scope.

Responsible disclosure: Inform the client about the vulnerability through a secure communication channel.

Written approval: Request updated authorization before conducting further tests.

non-malficence: Avoid actions that could cause damage (or) expose sensitive information.

Justification:-

Exploring the vulnerability without permission could result in data loss, service disruption (or) legal consequences. A critical vulnerability does not automatically give the tester permission to exploit it. Therefore, I would report the issue and obtain written authorization before proceeding. This approach maintains professional integrity while helping the company improves its security.

2. You are conducting a penetration test its network and discover that client's production database contains real customer financial data. you test plan calls for Exploiting a SQL injection vulnerability. How do you proceed without causing harm and what precautions should have been taken before it?

SQL injection is a vulnerability that occurs when an application incorrectly handles user input and allows database queries to be manipulated. If I discover this vulnerability in a production database containing real customer financial information. I must proceed with extreme care to protect customer privacy and prevent business disruption.

Steps to proceed safely.

1. Review the testing authorization:

Confirm that SQL injection testing and the affected production application are included in the approved scope.

2. Prefer a testing environment:

Whenever possible, reproduce the vulnerability in a staging environment containing dummy (or) anonymized data.

3. Use non-destructive testing:

Harmless test inputs to confirm the vulnerability without extracting financial records (or) modifying database contents.

4. Avoid sensitive data exposure.

Do not access customer account details, passwords, transaction records (or) other confidential information unnecessarily.

- monitor system performance:-

observe the application's behavior and stop testing if the data-
base becomes unstable (or) unexpected sensitive information
is exposed.

Notify the client.

Inform the designated security contanct about the vulnerability
and its potential impact.

- Prepare a detailed report.

Document the affected application, the evidence collected, the possible
consequences and recommended corrective actions.

Precautions before the engagement.

- Sign a contract and define the scope of testing
- obtain written authorization for production testing.
- establish backup and recovery procedures.

Justification: The principles of confidentiality, integrity and availability
must be maintained. The goal is to identify security weakness
without harming customers (or) the business.

During a black-box penetration test, you accedentally
trigger a DNS on a live condition server causing an outage.
Walk through what have done to prevent and what is your
responsibility now.

If my testing causes a production outage, I must act
immediately and take responsibility.

Prevention steps:-

1. Identify production systems and critical services before
testing.

2. Avoid aggressive scans and high-volume requests without explicit approval.

3. Use rate limits and safe testing methods

4. Agree on testing windows and emergency stop procedures.

5. monitor system performance throughout the test

Actions after the outage:-

1. Stop the test immediately.

2. Notify the client's designated emergency contact.

3. Help the authorized technical team

4. Preserve logs and document the actions that caused the outage.

Justification:-

A penetration tester is responsible for conducting tests carefully and responding professionally when something goes wrong. Ending the outage (or) continuing the test could increase the damage. Immediate communication cooperation and accurate documentation help restore trust and improve future testing practices.

(4). A client asks you to test teams red would detection capability what ethical and practical risks does this create, and how would you structure the engagement to protect yourself

iid situation describes a possible red team exercise in
which the organization wants to evaluate whether its
security team can detect and respond to realistic attack
keeping some defenses unaware of the test can
provide valuable information about the effectiveness of
security monitoring. However, the exercise must be properly
authorized and carefully controlled.

Ethical and practical risks:
misunderstanding the activity:
The IT team may interpret the simulated attacks as
a genuine security incident.

Business disruption:
Testing may accidentally intercept important services
(or) affect business operations.

unnecessary emergency
The security team may isolate systems, disable accounts
(or) initiate recovery procedures.

How I would structure the engagement:

1. Obtain written authorization from an appropriate senior
authority.

2. Define the systems, techniques, duration and limits
of the exercise.

3. Appoint a trusted emergency contact who can stop the test.

4. Decide which employees will remain unaware of the exercise.

Justification: A controlled, authorized test can measure real-world detection capability without unnecessarily endagering the organaization. The IT team does not necessarily need advance notice, but the exercise must have proper authorization and safeguards.

(5) you are asked to perform red team exercise versus a "vulnerability assessment. using a real world scenario of bank wanting to test physical and digital security.

Suppose a bank wants to evaluate the security of its online banking systems, ATMs, office network, and physical branches.

Vulnerability assessment

- Scan approved system for outdated software, misconfiguration and known vulnerabilities.
- Review firewall rules and network security.
- Check approved web applications for common vulnerability
- Assess physical security controls through authorized inspections

Prepare a report with risk ratings and remediation recommendations.

Example : Identify an outdated server (or) a misconfigured firewall without attempting to compromise the bank's operations.

Red Team Exercise:-

Goal : Evaluate whether the bank can detect and respond to a realistic attack.

- Simulate an authorized attacker attempting to reach a defined objective.
- Test approved physical entry controls, such as whether access badges are properly checked.
- Simulate phishing (or) credential attacks using agreed safeguards

Example : Simulate an attempt to reach a designated test account (or) protected environment and determine whether the bank detects the activity.